

Network Security

Theory Class Nº9

Jorge Sa Silva
sasilva@deec.uc.pt
University of Coimbra
Portugal

Outline

- Block chain
- Security in IoT



Next lessons

Week	Theor. Lesson	Pract. Lesson
Nov. 10	Block Chain, IoT Security	Assign. 3
Nov. 17	Federated Learning	Assign. 3 – D1
Nov. 24	Assign. 3 – D2	Proj2
Dec. 1	Proj2 – D1	Holiday
Dec. 8	Differentiated Privacy	Holiday
Dec. 15	Revisions	Proj2 – D2

Security in Communication Networks



- **Perspective**
  - User
  - Manager
  - Developer
- **Security:** type of attacks
- **Ingredients**
  - Requirements:
    - Data integrity
    - User authentication
    - Confidentiality
  - Kerckhoff's principle
  - Random and pseudo-random generators
  - Symmetric Encryption
  - Asymmetric Encryption
  - Hash
  - Diffie-Hellman
  - Message Authentication Code (MAC)
  - RSA
  - Digital certificates
  - …

- **Applications**
  - Digital signatures
  - TLS
  - Darkweb
  - Blockchain
  - Firewall
  - VPNs
  - …



Blockchain

Blockchain – ingredients

- Asymmetric encryption
- Hash functions

What is Blockchain?

- Distributed system
- Uses cryptographic mechanisms
- Implement ledgers (livros de registo / livros razão)
- Initially known because of Bitcoin

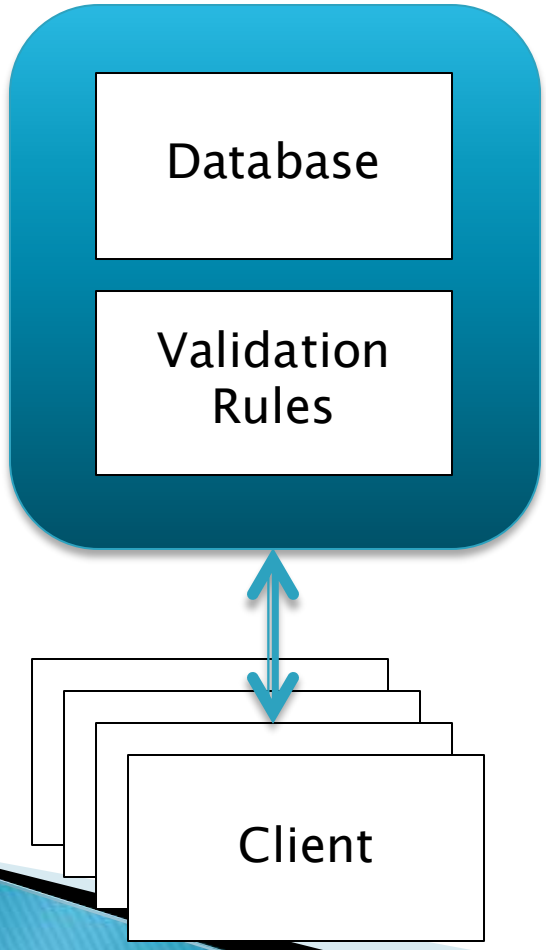
When used?

- Needed to implement a distributed “database” of transactions
- Needed by multiple entities
- Without mutual trust
- Without the intermediation of third parties

History....

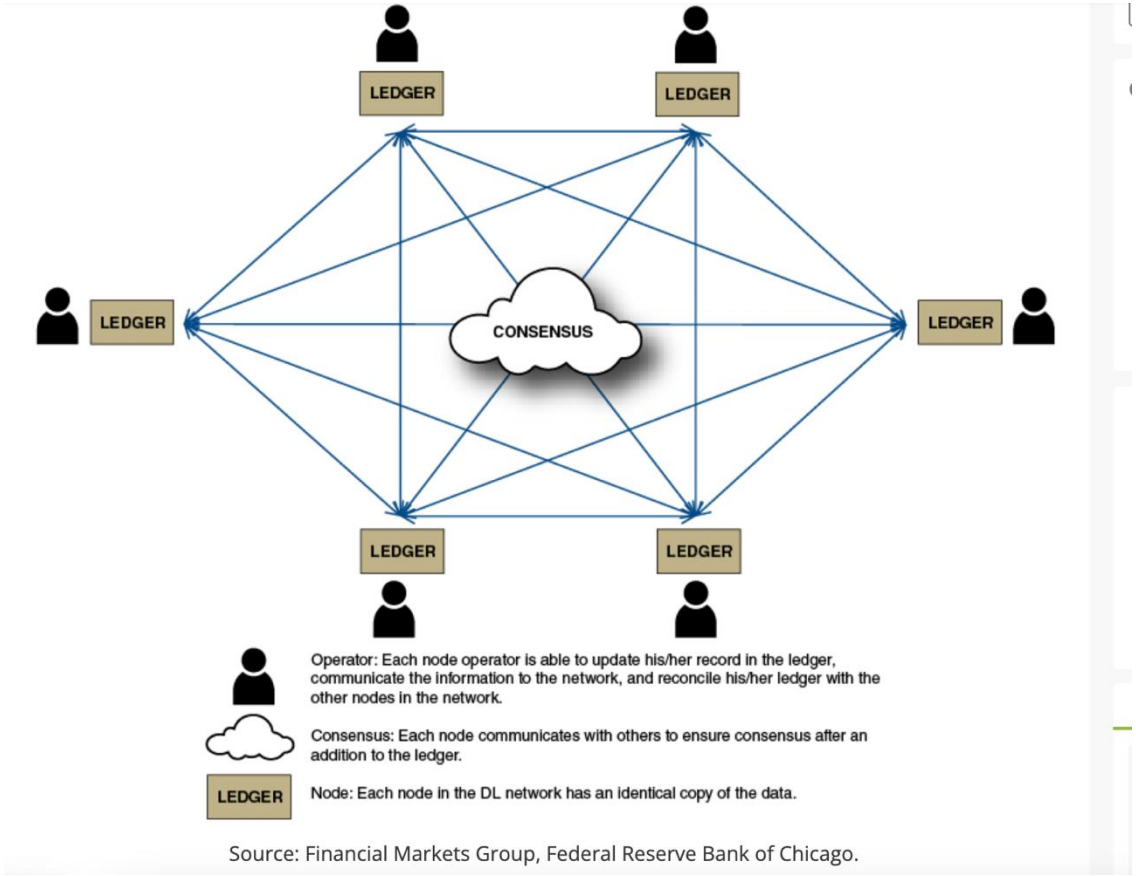
- Blockchain is not Bitcoin
- Satoshi Nakamoto (pseudonym) and his/their creation, Bitcoin, popularized Blockchain technology. (There are currently arguments that Bitcoin was not the first blockchain.)
- On October 31, 2008, *Satoshi Nakamoto* released the Bitcoin White Paper outlining a purely peer to peer electronic cash/digital asset transfer system. This is the first popular implementation of Blockchain and is attributed as birthing today's Blockchain industry.
- Since then, additional Blockchains have been popularized, Ethereum, various Hyperledger project solutions, as well as numerous others including "Blockchain like" solutions such as *GuardTime's KSI* products
- Today there are various *flavors* of Blockchain.

Traditional approach



- Centralized ledger
- Controlled by an authority
- Access protected writes to an authoritative database
- Transactions, time stamping, contracts, etc.

Blockchain approach



Source: Financial Markets Group, Federal Reserve Bank of Chicago.

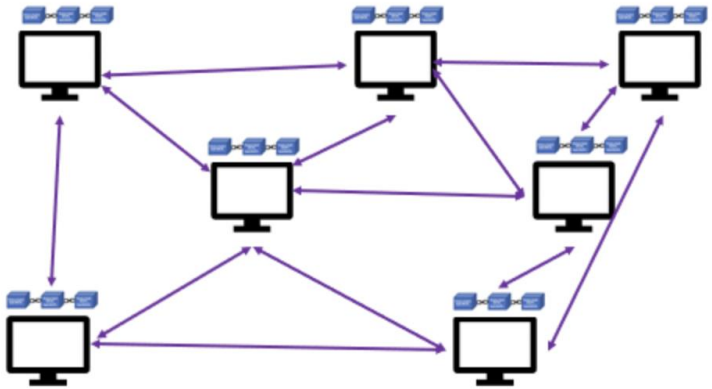
- Public ledger
- You can insert, select data, but **can't** update or delete data
- Based on **p2p** (peer-to-peer) technology, cryptology
- Operator / Miner
- Each transaction can be identified by the sender's public keys

Blockchain properties

- Decentralisation — no single party has control over what information goes in
- Consensus — many different parties store exact copies of the same ledger, so the majority has to agree on the information being added
- ‘Add-only’, meaning you can’t edit what’s already there, you can only add information
- New information can’t conflict with what’s already been added
- Information is able to be accessed and replicated by everybody on the network

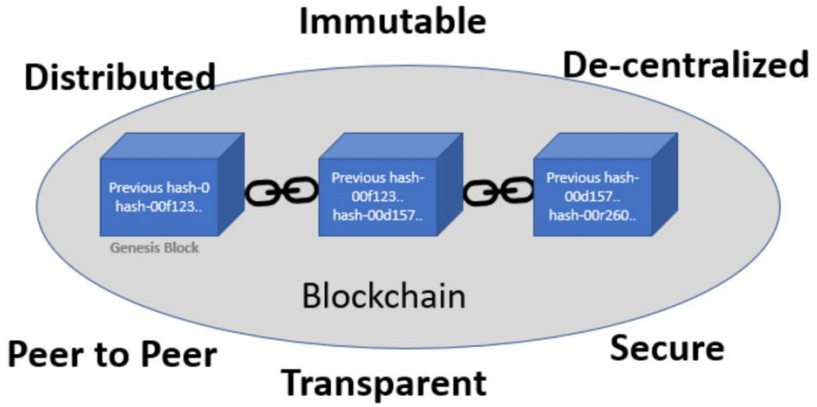
Miners

- Mining is the process by which new transactions are entered into circulation;
- It is also the way that new transactions are confirmed by the network and a critical component of the maintenance and development of the blockchain ledger.
- "Mining" is performed using sophisticated hardware that solves an extremely complex computational math problem.

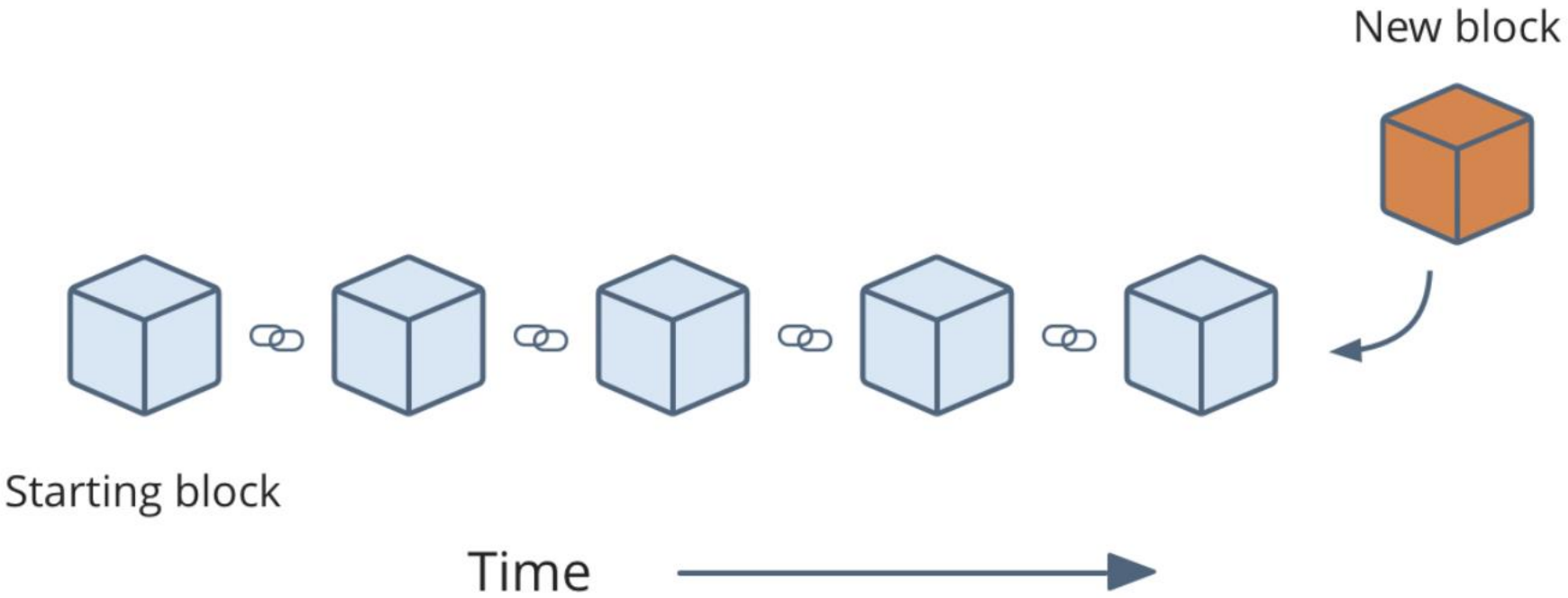


Ledger (livro razão)

- It is a series (or chain) of blocks on which transaction details are recorded after suitable authentication and verification by the designated network participants.
- A distributed ledger is decentralized to eliminate the need for a central authority or intermediary to process, validate or authenticate transactions.
- Timely ordered
- All files in the distributed ledger are then timestamped and given a unique cryptographic signature.
- All of the participants on the distributed ledger can view all of the records in question.

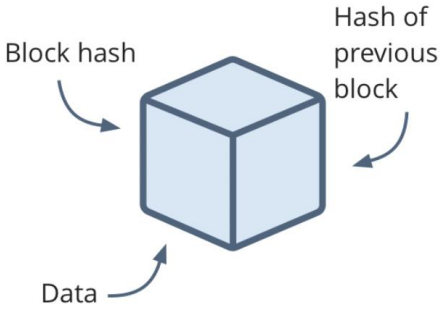


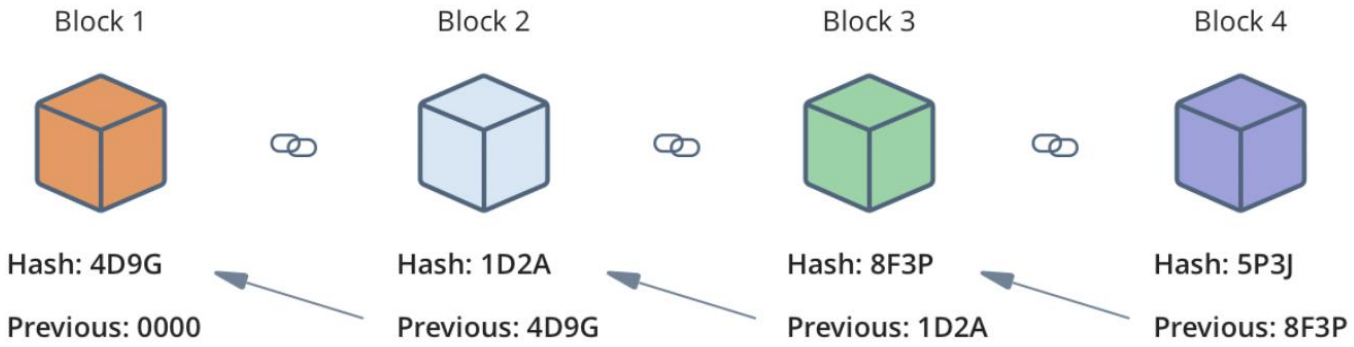
Ledger – linear chain of blocks



Block

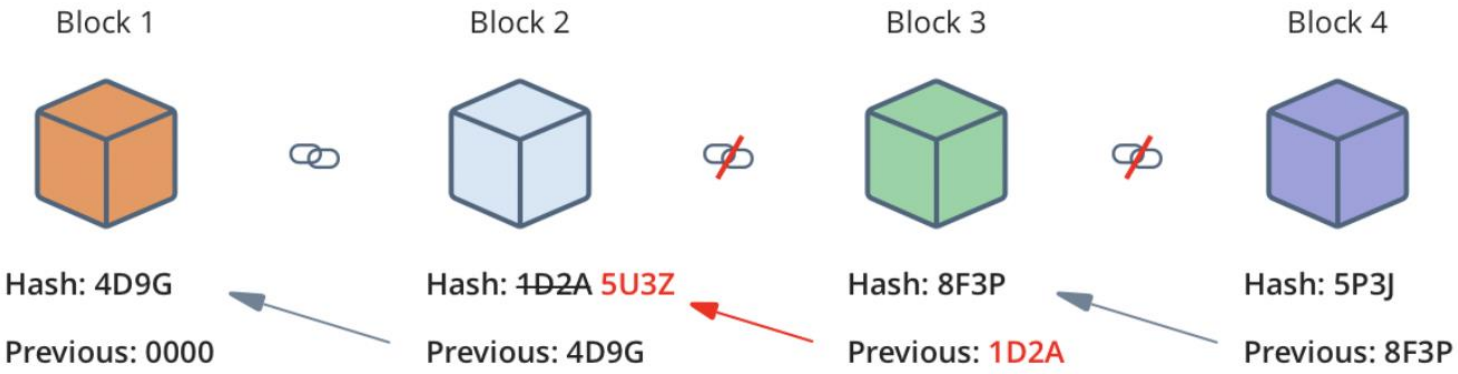
- Data on transactions
- The block's hash
- The hash of the previous block





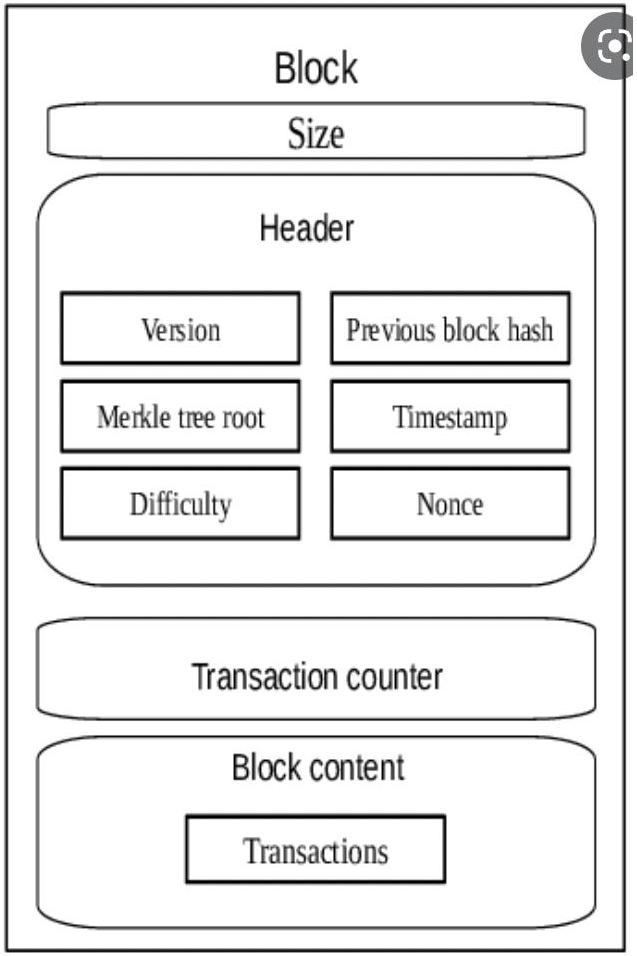
Block tamper

- when block 2 is changed



- The ledger exists on thousands of computers all over the world, so to fake that transaction, we'd need to somehow get access to over 50% of the computers, and repeat the mining process for all the ledgers we control.

Block structure



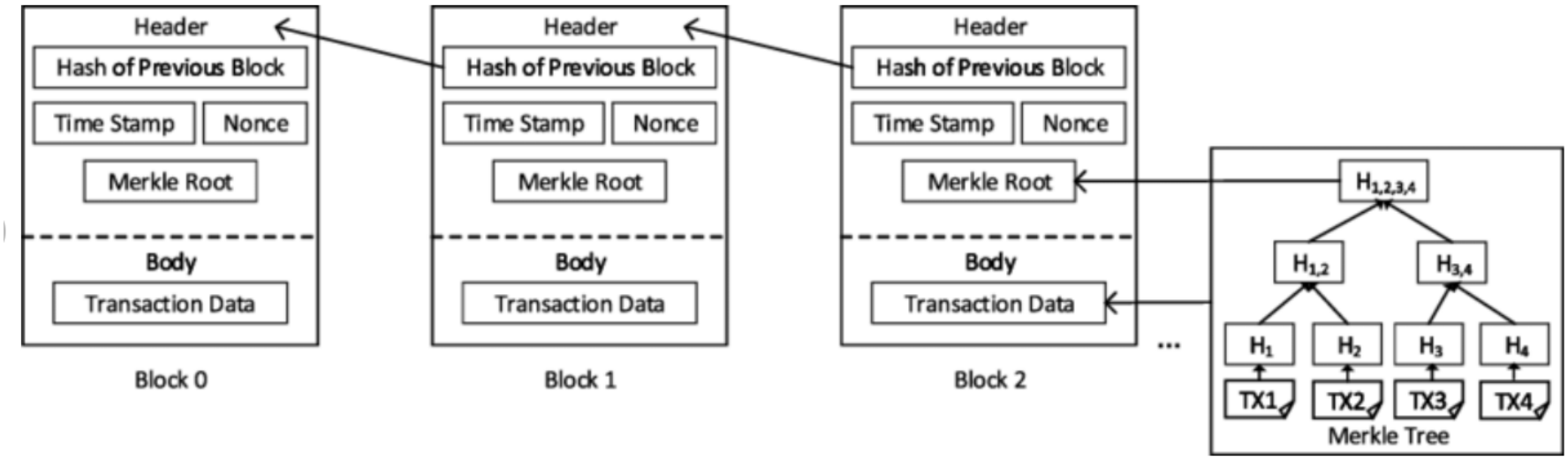
Block structure

- **Magic number**: This 4-byte field indicates the file format
- **Blocksize**: This 4-byte field sets a cap on the amount of data that can be contained in a block. The Bitcoin block size is limited to one megabyte.
- **Block header**: This 80-byte field consists of six individual components.
- **Transaction counter**: This field can range in size from one to nine bytes and is a positive integer that represents the number of transactions contained in the block.
- **Transactions**: This variable size field contains the list of all transactions contained in the block and is typically filled with enough transactions to fill the 1MB Bitcoin block size limit.

Block structure – header

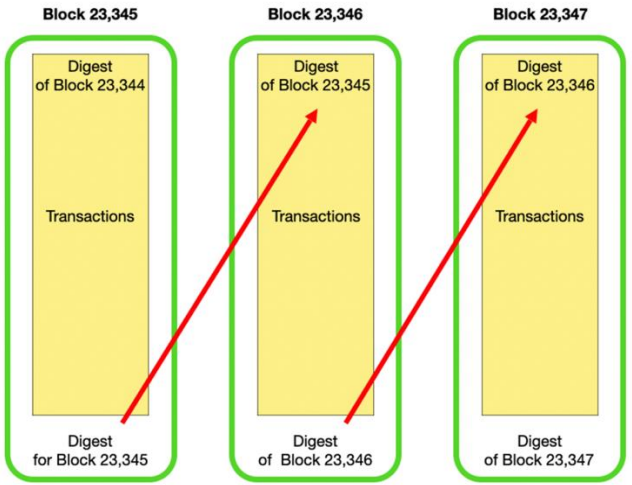
- **Version**: This 4-byte field indicates the version number of the protocol being used."
- **hashPrevBlock**: This 32-byte field contains a 256-bit hash of the previous block header.
- **hashMerkleRoot**: This 32-byte field contains a 256-bit hash of the root of the Merkle tree of all the transactions in the current block.
- **Time**: This 4-byte field contains a timestamp of the current block that is used to situate it chronologically in the blockchain.
- **Difficulty**: This 4-byte field contains the target difficulty of the current block which determines how difficult the target hash will be to find.
- **Nonce**: This 4-byte field contains a 32-bit number that a miner must alter in order to correctly solve the computational puzzle for the current block.

Merkle Hash


Header
Hash of Previous Block
Time Stamp
Nonce
Merkle Root
Body
Transaction Data
Block 0
Block 1
Block 2
$H_{1,2,3,4}$
$H_{1,2}$
$H_{3,4}$
H_1
H_2
H_3
H_4
TX1
TX2
TX3
TX4
Merkle Tree

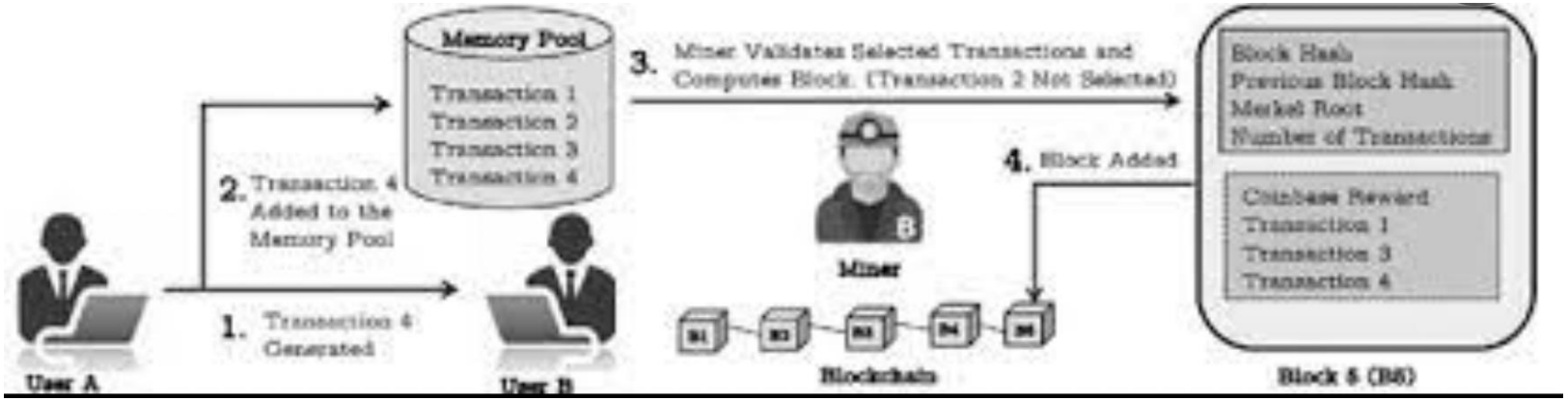
Ledger confidence

- Use of public keys and digital signatures to guarantee the authenticity of each transaction.
- Each user uses his public key to authenticate the transaction
- Transactions that make up the body of each block are protected by a hash code included in the block header.
- Each block integrated in the linear chain is linked to the previous block by a hash code (SHA-256). Changing a block without impacting this hash code, or changing the hash code of all blocks in the chain is computationally infeasible.
- Several users keep copies of the total ledger. A consensus mechanism ensures that all blockchain records are consistent.



Solving a bock (criação do bloco)

Memory pool

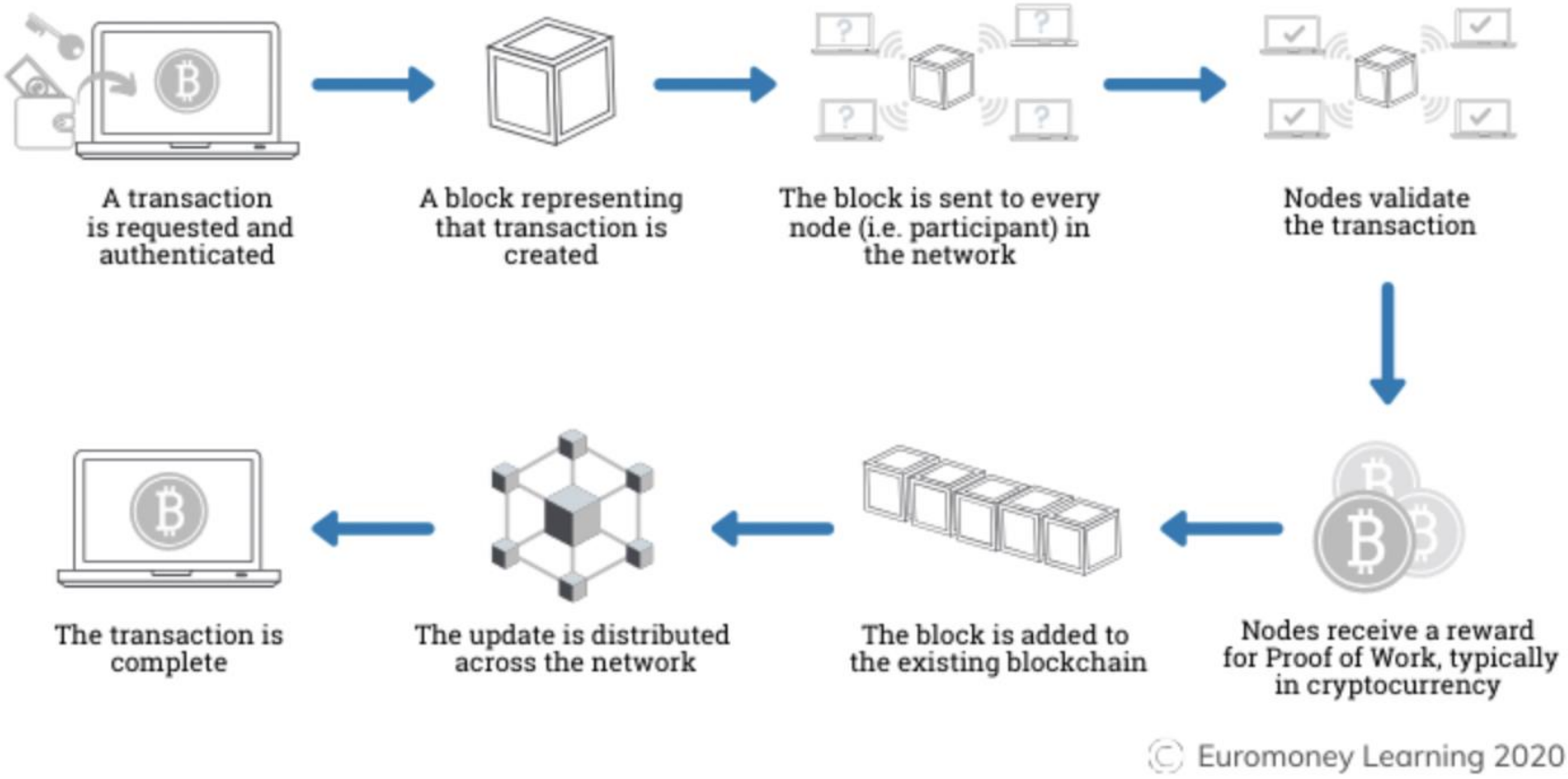


The Nonce / Hash Loop

- The algorithm to make a new block:

1. Verify the hashes of all the previous blocks
2. Build a new block with a random nonce
3. Hash the new block. Does it have N zeros?
   - No? Go back to Step 2
   - Yes? Send your new block to everyone!

Solving a bock (criação do bloco)



Forks

- A Fork is a blockchain split that produces two competing branches.
- Can be **accidental** or **intentional**.
- Intentional forks are further categorized as either **soft forks** or **hard forks**.
- Accidental forks are resolved by the blockchain.
- Intentional forks are used to implement new consensus rules.
- **Hard forks** require nodes to be upgraded to the new consensus rules or to rollback the state.
- **Soft forks** don't require nodes to be upgraded to the new consensus rules. Some cryptocurrencies, like **Bitcoin Cash**, are created using hard forks.

Forks

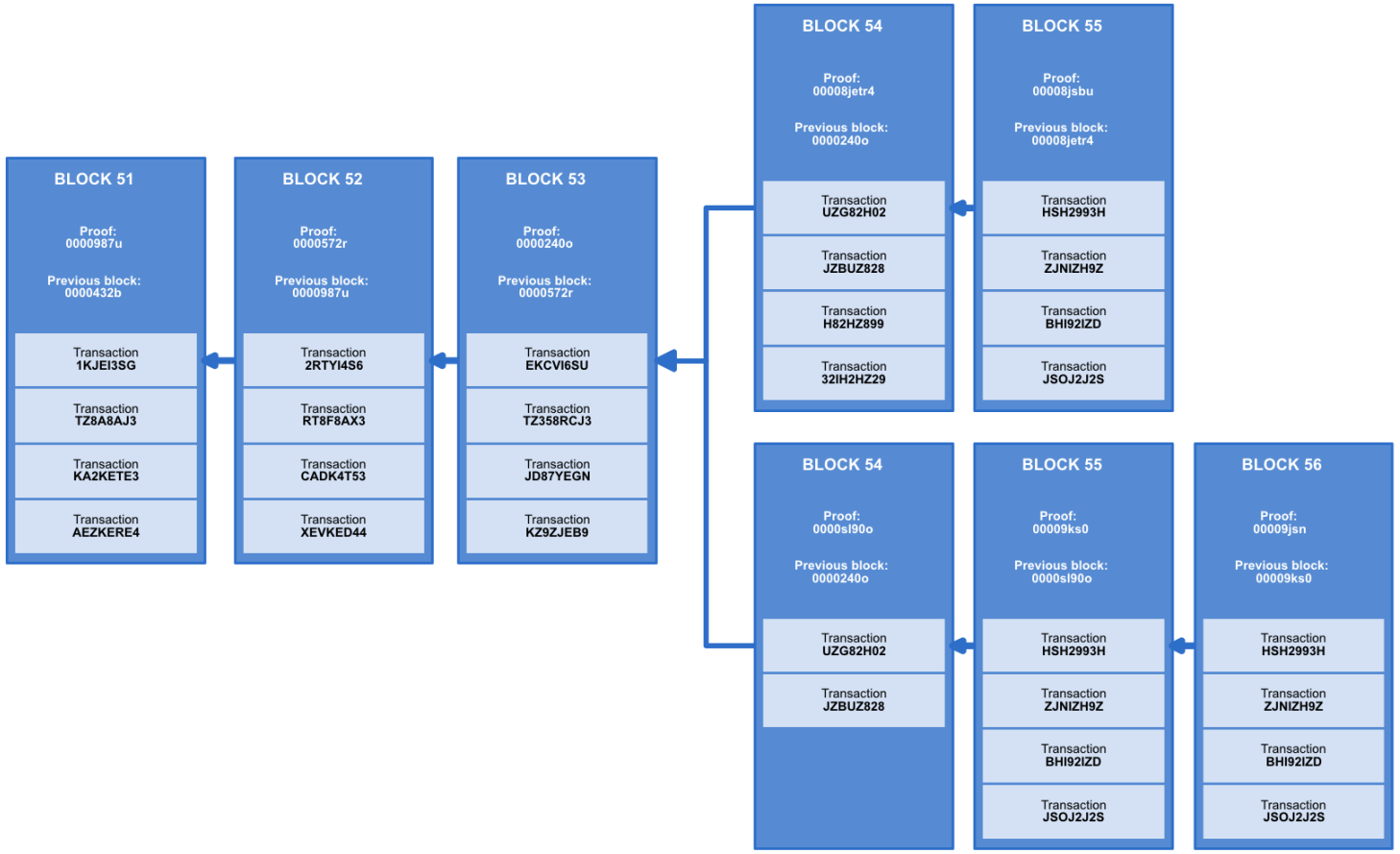


Image source: Scorechain

Accidental forks

- At any given moment, thousands of miners are competing to create a new block.
- With so much mining going on at once, two or more miners sometimes mine a new block at the same time.
- When this happens, an **accidental fork** is created.
- The problem is solved when new blocks are added to one of the chains.
- When that happens, the network continues working on the longer chain and abandons the shorter one.

Intentional forks (hard forks)

- A hard fork is a fork that introduces new rules and requires the nodes in the network to upgrade their software.
- Consider a blockchain with a block size limit of 1 MB. If you wanted larger blocks that could store up to 8 MB of data, you would have to implement a new set of rules that would increase the block size limit from 1 MB to 8 MB.
- When a **hard fork** occurs, the community members (users and miners) must make a decision. They can either update their node and switch to the newly-forked chain, or they can keep running the old software.

Intentional forks (soft forks)

- As opposed to hard forks, changes implemented by **soft forks** make the chains **forward compatible**.
- To be forward compatible, blocks created under new rules must also be valid under the old rules.
- Due to that, a soft fork does not require nodes to be upgraded. They can keep running the old software version and still participate in the upgraded network as validators of transactions.
- Soft forks can be activated by users (**UASF – user activated soft fork**) or miners (**MASF – miner activated soft forks**).

Consense models

- A consensus mechanism is a **fault-tolerant mechanism** that is used in computer and blockchain systems to achieve the necessary agreement on a single data value or a single state of the network among distributed processes or multi-agent systems, such as with blockchain and cryptocurrencies.
- They define the rules that determine which miner publishes the next block in the chain.

Types of blockchain consensus mechanisms

Proof of Work

Proof of Work mechanim involves miners who solve complicated mathematical puzzles to produce a new block.

Proof of Stake

Proof of Stake uses a randomized process to figure out who gets a chance to produce the next block.

Delegated Proof of Stake

In Delegated Proof of Stake process, users can stake their coins and vote for a particular number of delegates to create a new block.

Proof of Capacity

Proof of Capacity method stores solutions of complex mathematical puzzles in digital storages such as hard disks that are used to create new blocks.

Proof of Elapsed Time

Proof of Elapsed Time process randomly and fairly decides the producer of a new block based on their waiting time.

Proof of Identity

Proof of Identity is a cryptographic evidence for a user's private key that is cryptographically attached to a specific transaction.

Proof of Authority

In Proof of Authority mechanism, the identities of validators in the network are at stake.

Proof of Activity

Proof of Activity mechanism is a hybrid of Proof of Work and Proof of Stake.

Block chains

- Public
- Private

Blockchain limitations

- Resources used
- Dead of blockchain

Attacking the Blockchain Network

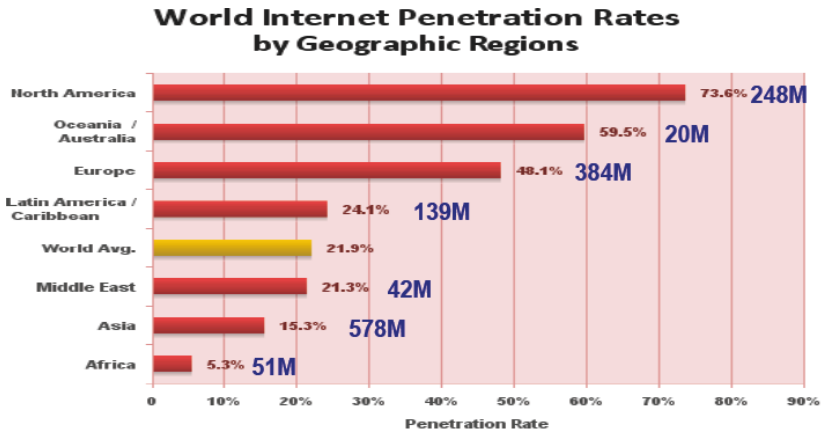


- Denial of Service Attacks
  - An attacker can create a large number of spam transactions and transmit them to the network (similar to a DoS attack on a webserver).
- Eclipse/Routing Attacks
  - The network is split up into two or more isolated groups. Both attacks can be used to facilitate a double-spend attack (by sending a different transaction to each isolated individual/group) or a 51% attack (by filtering the victim's view of the network state so that they mine a version of history that's in the attacker's favor)

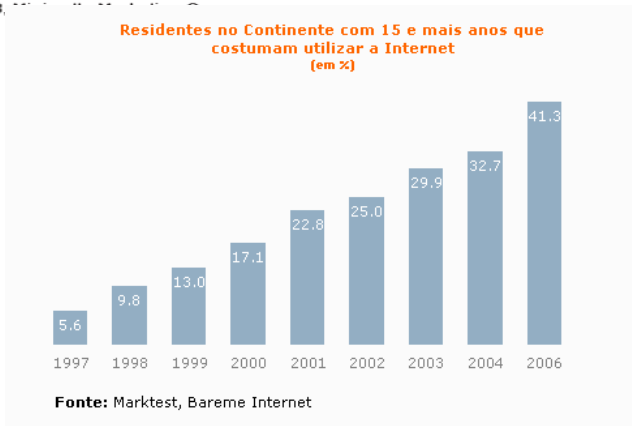


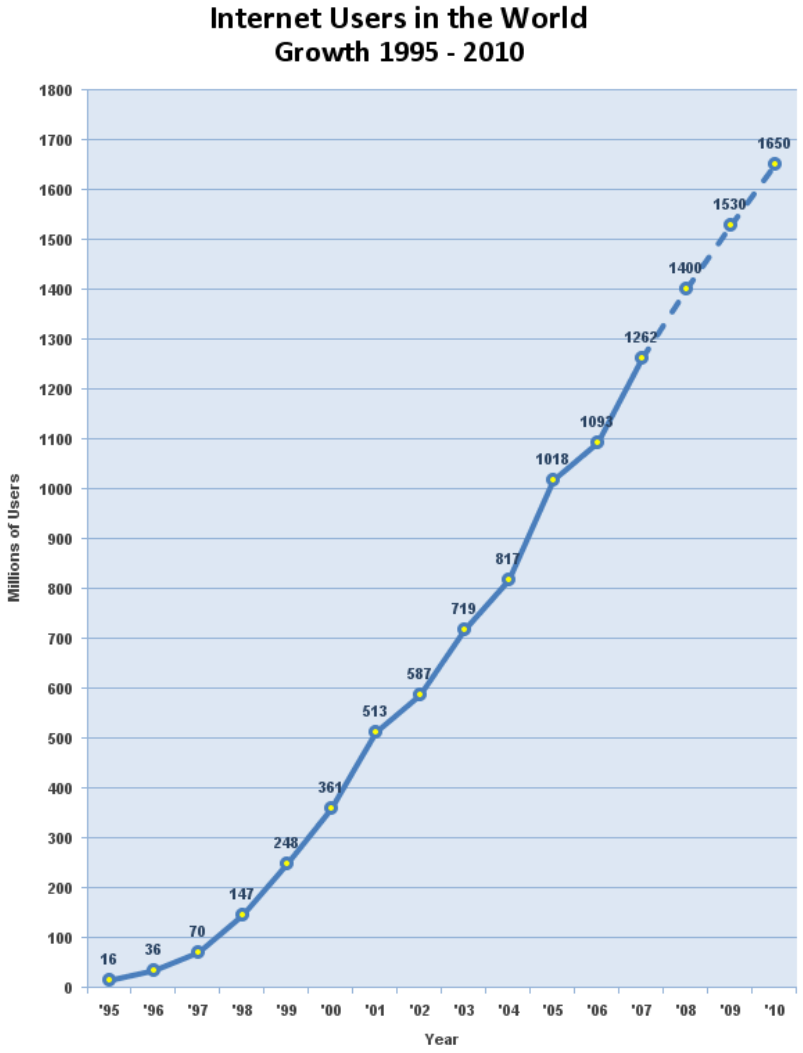
Security in IoT

Internet



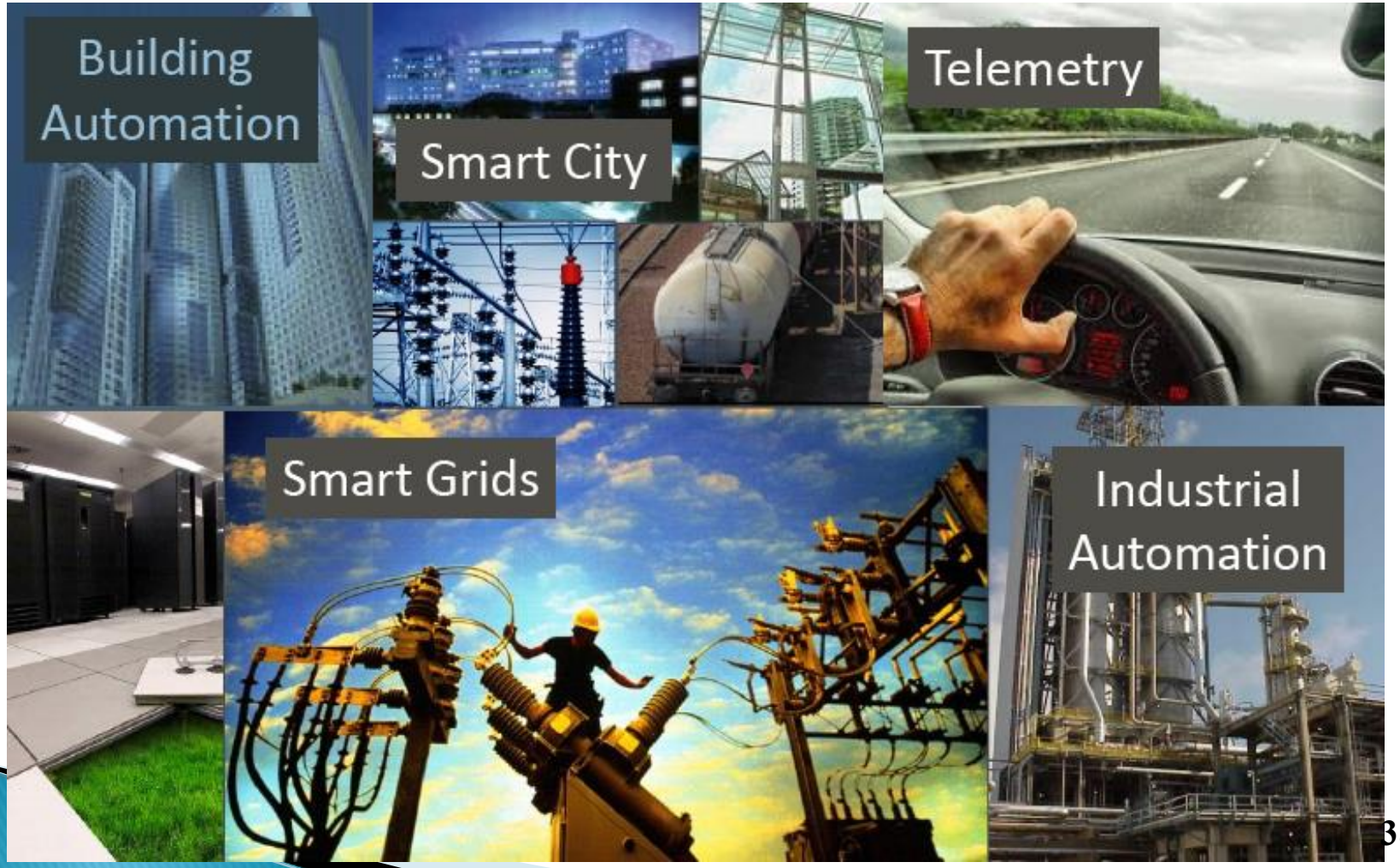
Source: Internet World Stats - www.internetworldststs.com/stats.htm
Penetration Rates are based on a world population of 6,676,120,288 for mid-year 2008 and 1,463,632,361 estimated Internet users.
Copyright © 2008,



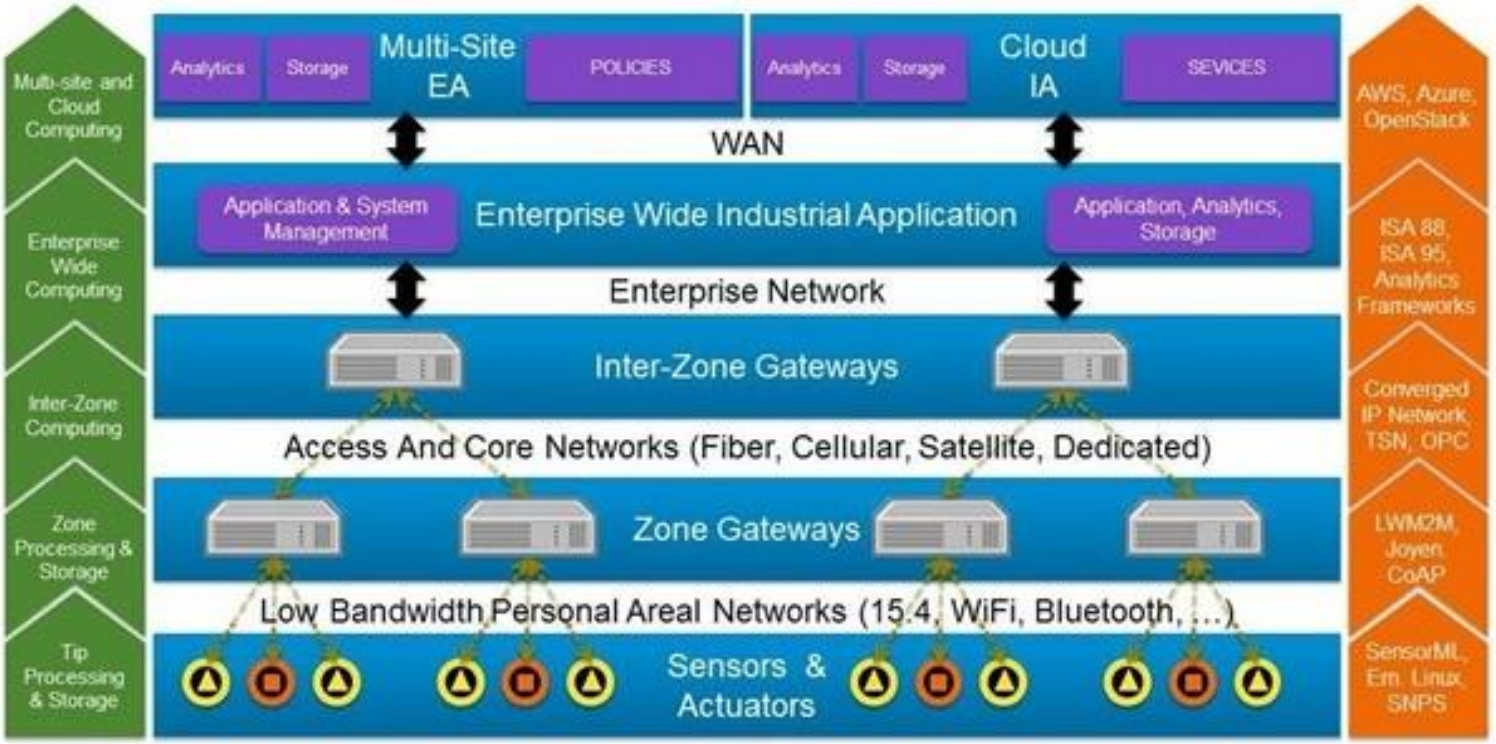


Source: www.internetworldstats.com - January, 2008
Copyright © 2008, Miniwatts Marketing Group

The New Internet

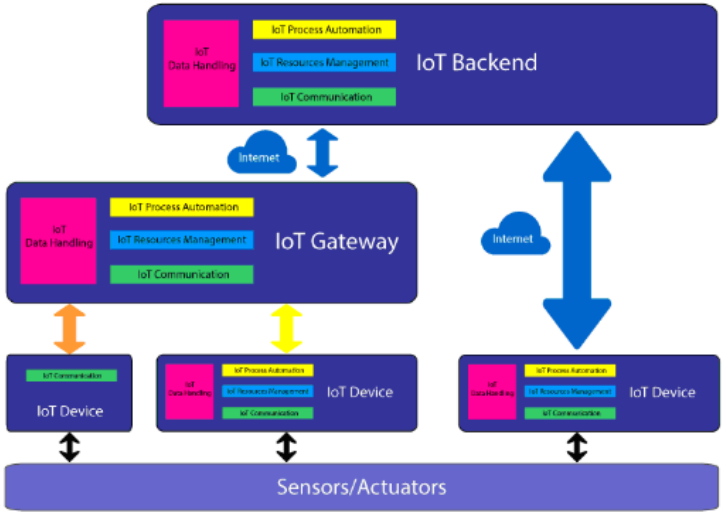


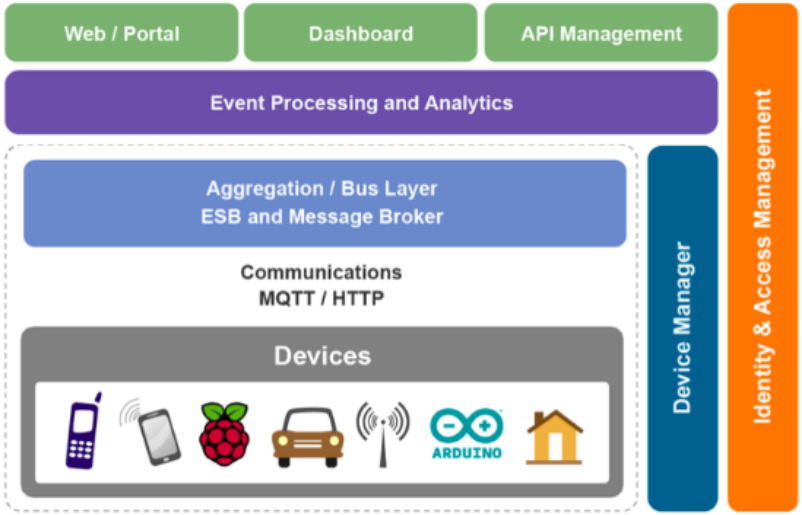
IoT Architecture



Partner Ecosystems

Others IoT architectures





The Things

- Refrigerator
- Intelligent refrigerator
- IoT refrigerator

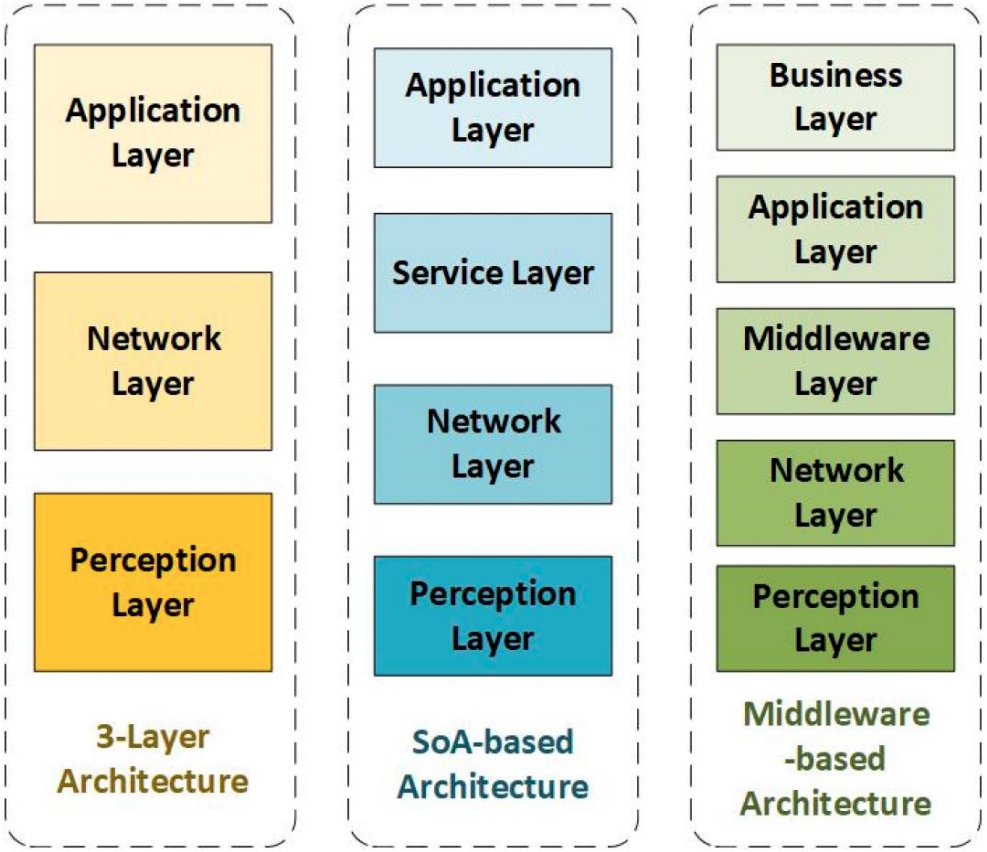
The Things

- Car in 1970 and a Car in 2015
  - Computational intelligence helps the user with a simple interface

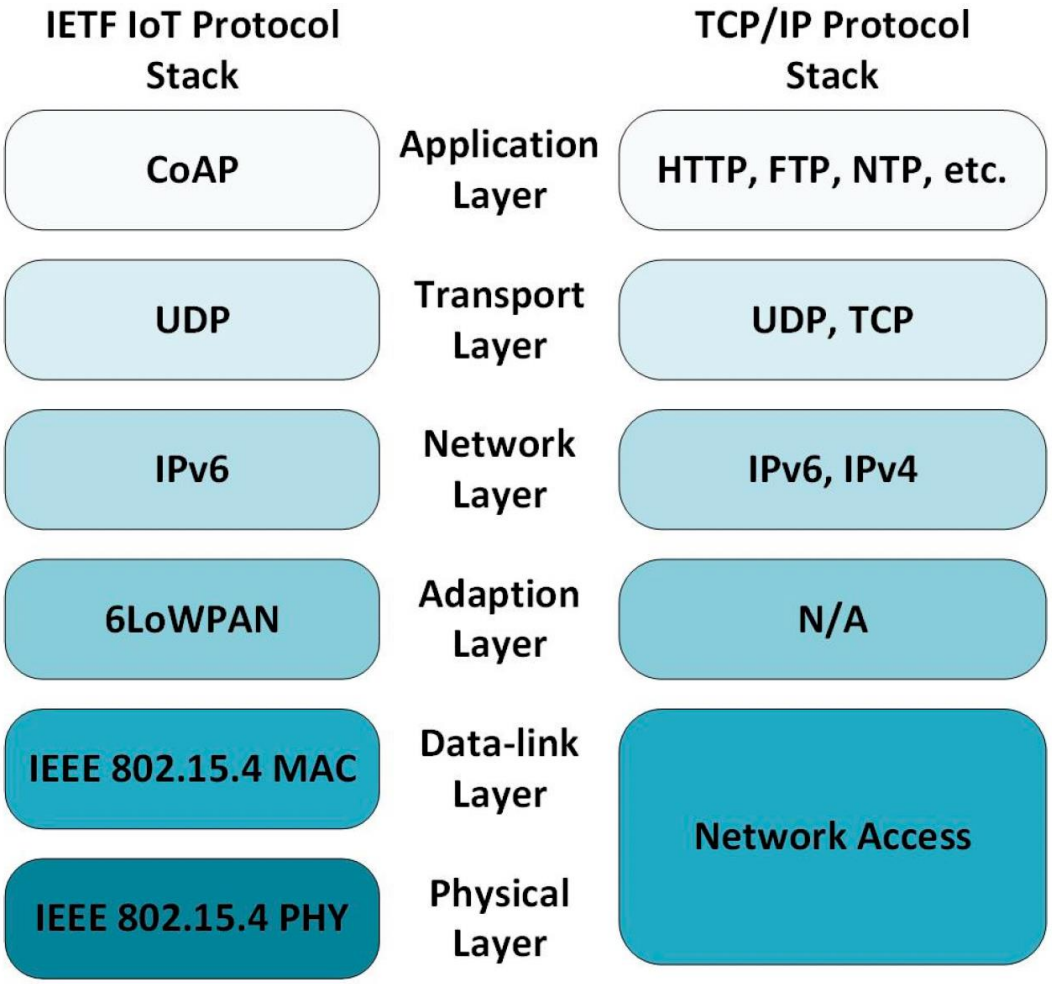
Internet of Things Architectures

- **Scalable** – in order to manage the increasing number of devices and services without degrading their performance;
- **Interoperable** – so that devices from different vendors can cooperate to achieve common goals;
- **Distributive** – to allow to create of a distributed environment in which, after being collected from different sources, data are processed by different entities in a distributed way;
- Able to operate with **few resources**, since objects generally have little computing power;
- **Secure** – so as not to allow unauthorized access.

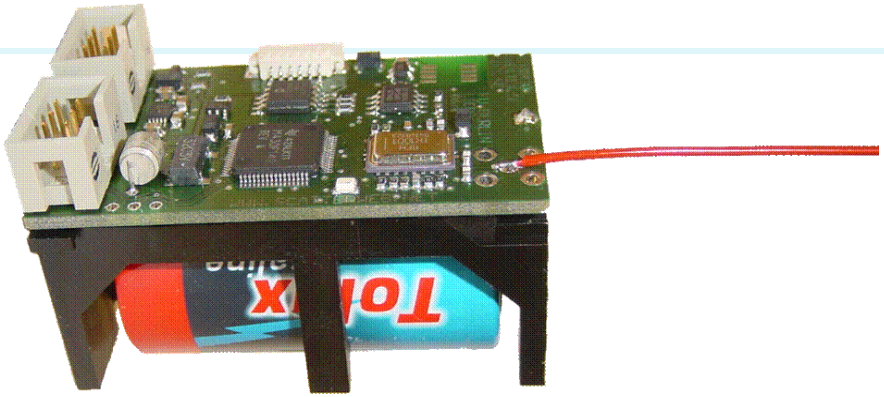
Most common IoT architectures.



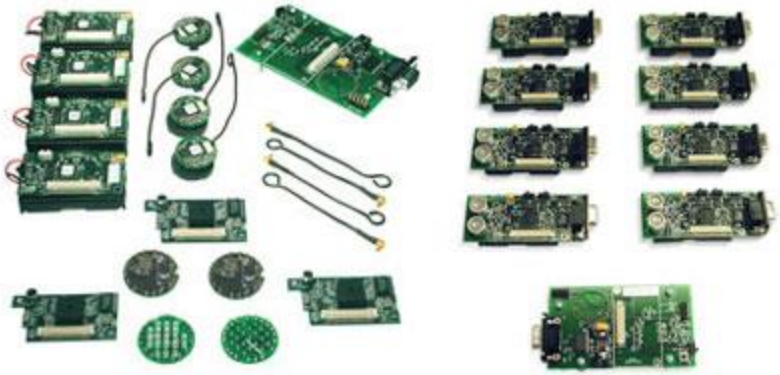
IoT Architectures



Wireless sensors as an important Thing







Sensor nodes



- One or more sensors
- Small processors
- Low memory
- Low battery
- Low transmission rates (**wireless**)

➢ **MOBILITY**

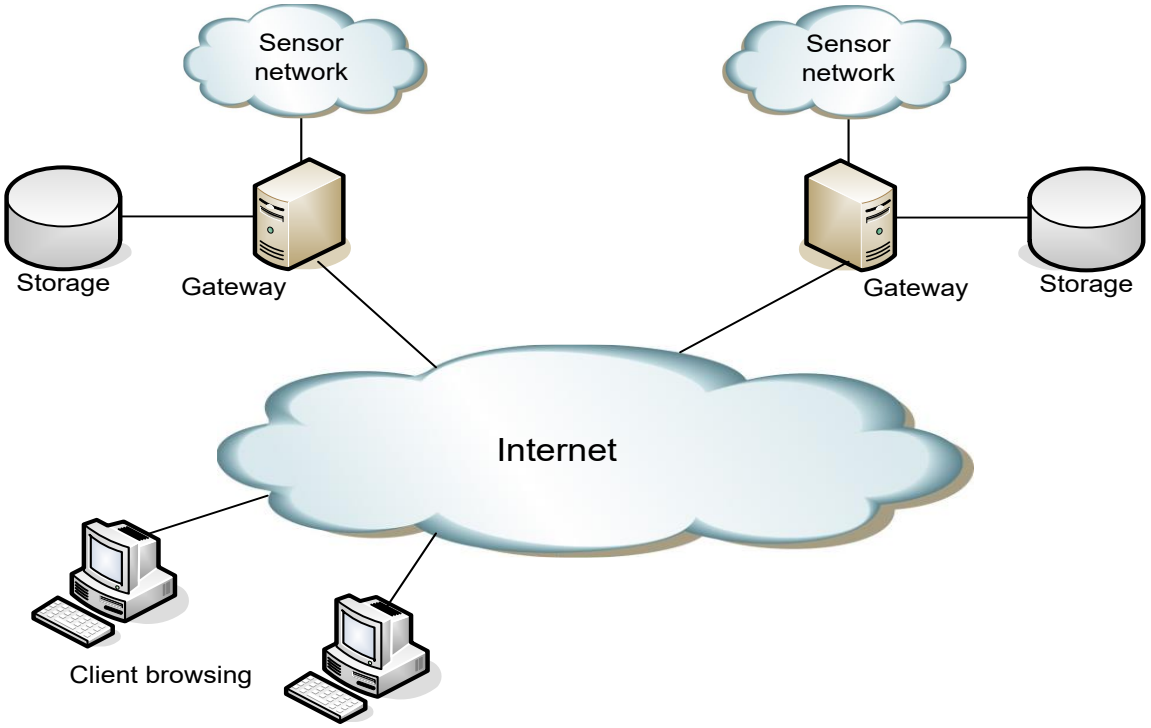
What's a WSN/IoT?



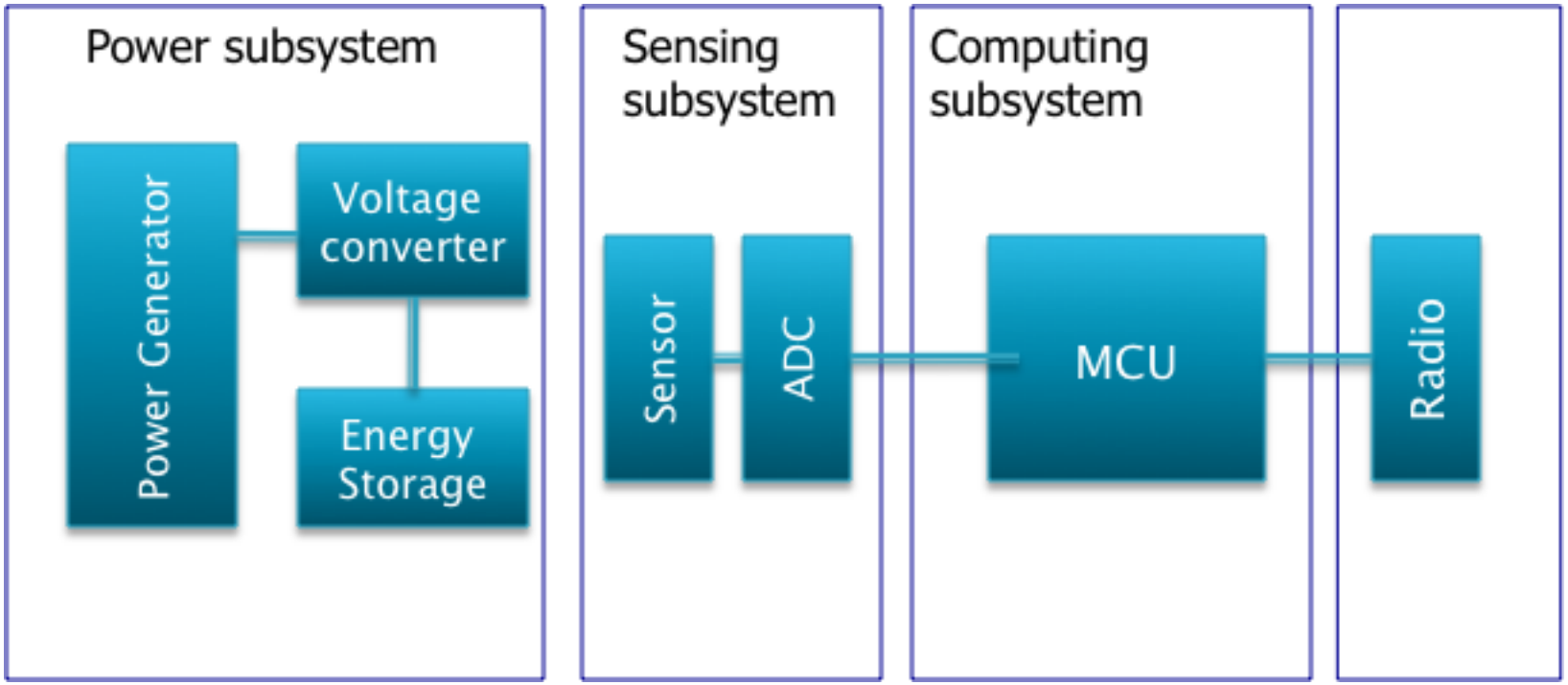
- New class of distributed systems
- Physical-world-aware networked systems
- Networks of many different types of sensors
  - Seismic
  - Magnetic
  - Thermal
  - Visual
  - Infrared
  - Acoustic
- Able to monitor a wide variety of ambient conditions

What's a WSN/IoT device? (3)

- WSNs can expand the Internet into the physical world



Hardware Architecture



Applications

- Environmental monitoring
  - Habitat monitoring
  - Wildlife conservation
- Industrial sensing and diagnostics
  - Manufacturing automation
  - Chemical products tracking
  - Disaster prevention and recovery
- Infrastructure protection
  - Power grids
  - Water distribution
  - Smart transportation
  - Roads/Vehicle safety
  - Traffic management and control

Applications (contd.)



- Military sensing
  - Multitarget tracking
  - Movement tracking
  - Perimeter protection
- Context-aware computing
  - Intelligent home
  - Building monitoring and control
  - Baby-sitting and children monitoring
  - Responsive environment
  - Security and surveillance

Applications (contd.)



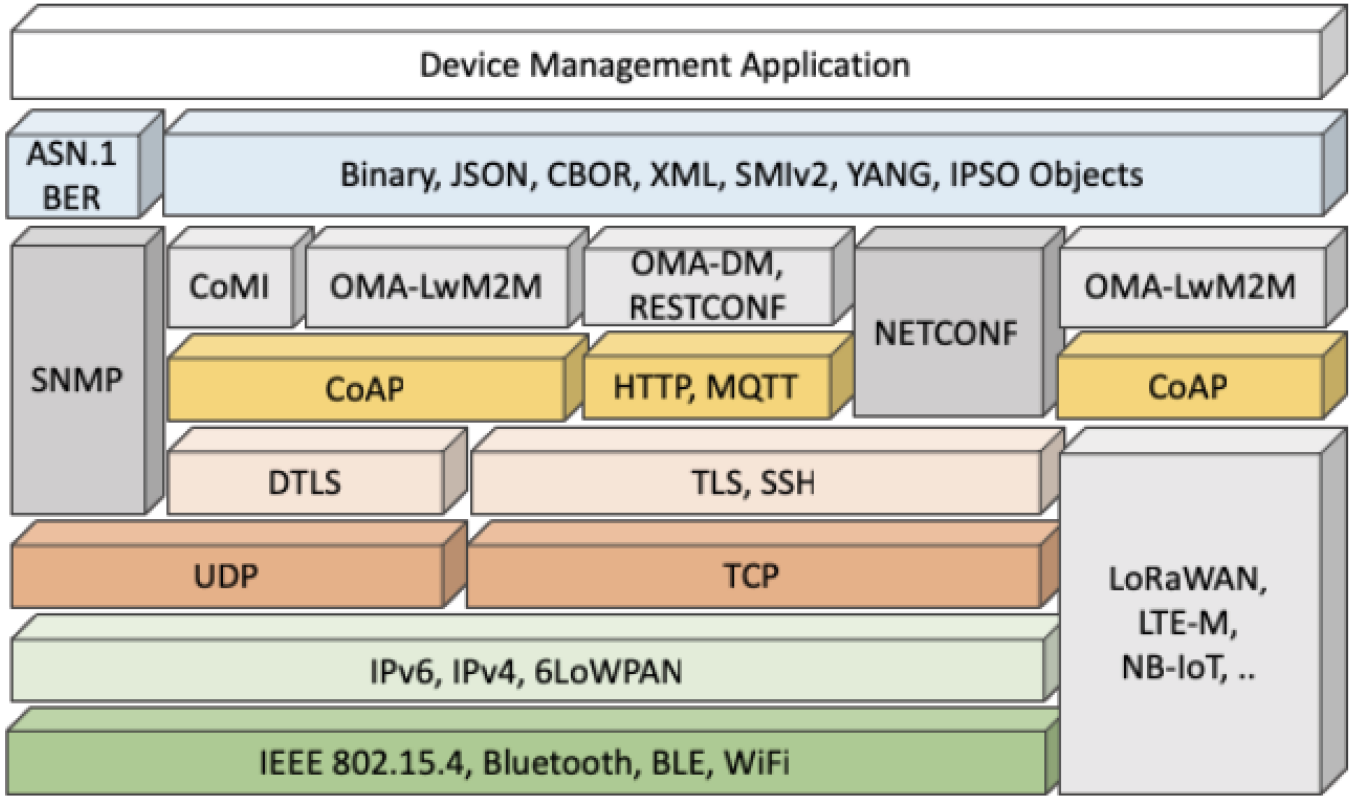
- Healthcare
  - Life signs monitoring
  - Remote tracking of patients
  - In-home elderly care
- Commercial applications
  - Inventory control
  - Product quality control
  - Smart office spaces
  - Environmental control in office buildings

IoT/WSN paradigms



- End to end principle does not hold,
- Nodes are single-use rather than multitasking,
- Collaborative rather than independent operation is the norm.

Internet of Things Stack



Network protocols

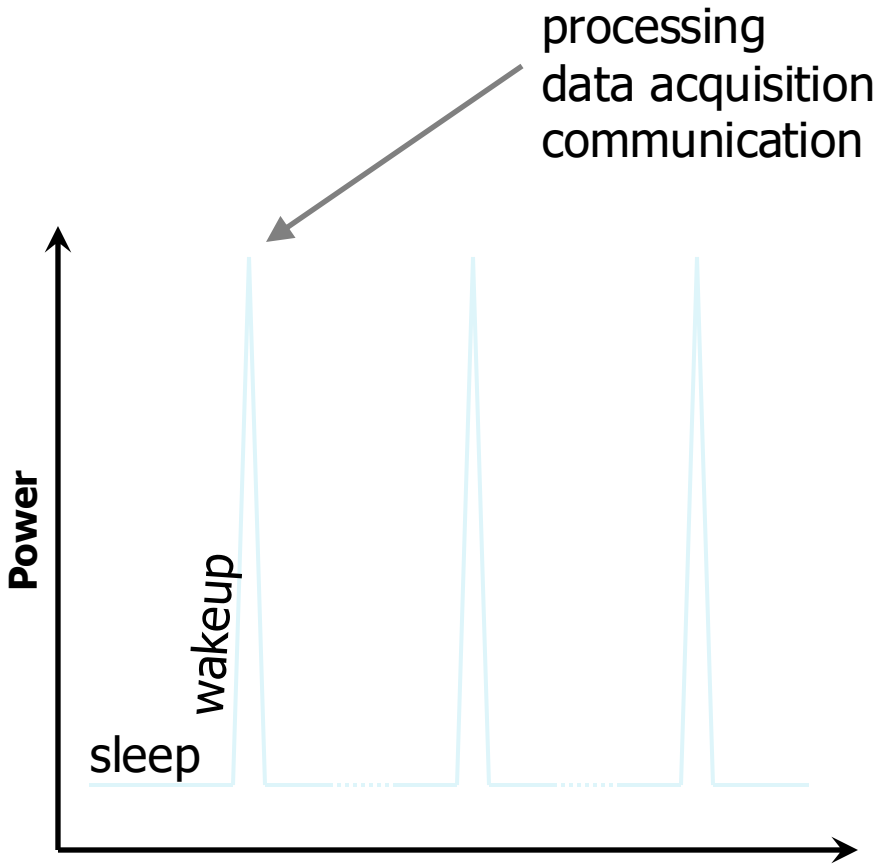
- Network layer protocol requirements:
  - Power efficiency
  - Data-centric
  - Attribute-based addressing
  - Location awareness
  - Data aggregation
  - Efficient routing
  - Integration with other networks (especially the Internet)

Requirements of MAC Protocols

- Traditional MAC Protocols
  - To maximize the throughput
- IoT MAC Protocols
  - Energy efficiency
  - Adaptively
  - Scalability
  - Fairness
  - Latency
  - Throughput
  - Feasibility

Typical WSN's applications

- Periodic
  - Data Collection
  - Network Maintenance
  - *Majority of operation*
- Triggered Events
  - Detection/Notification
  - *Infrequently occurs*
    - *But… must be reported quickly and reliably*
- Long Lifetime
  - Months to Years without changing batteries
  - Power management is the key to WSN success



Security of IoT

- What makes IoT different from traditional systems.
- Why security is harder in IoT (limited resources, heterogeneity, scale, update challenges).

IoT Threat Model (Classification of attacks)



- Physical attacks (tampering, side-channel)
- Network attacks (DoS/DDoS, MITM, jamming, replay)
- Cloud/backend attacks
- Firmware and software attacks
- Identity spoofing and device impersonation

Security at the Physical Layer



- Jamming and anti-jamming
- Radio eavesdropping (only listen)
- Vulnerabilities in BLE, RFID, LoRa, Zigbee

Secure Communications

- Cryptography for resource-constrained devices.
- TLS (TCP) /DTLS (UDP): differences and use cases.
- Security in IoT protocols:
  - MQTT (ACLs, authentication, TLS)
  - CoAP ("simplified" HTTP)
  - OPC-UA (industrial)
- Typical attacks: MQTT hijacking, CoAP amplification.

IoT Hardening

- Principle of least privilege applied to IoT devices
- Secure storage
- Avoiding insecure defaults (Telnet, HTTP without TLS)
- Secure factory configurations
  - Vulnerabilities found in:
    - IP cameras
    - Home routers
    - Connected vehicles
    - Smart meters

Privacy in IoT

- GDPR and Edge Privacy
- Data minimization
- Differential Privacy & Federated Learning

Security in Industrial IoT (IIoT)

- Industrial protocols: Modbus, OPC-UA, Profinet, etc.
- Security in OT (Operational Technology) networks
- Zero-Trust architectures for IIoT